

KRİPTOQRAFIYA KURSU

Mühazirə 1: Kriptoqrafiyaya Giriş

Ətraflı mühazirə qeydləri

Həftə 1: Əsas Anlayışlar və Prinsiplər

September 23, 2026

Contents

1 Giriş	3
2 Kriptografiyanın Gündəlik Tətbiqləri	3
2.1 E-poçt Təhlükəsizliyi	4
2.2 Mesajlaşma Tətbiqləri (WhatsApp, Signal)	4
2.3 Bank Kartları və EMV Texnologiyası	4
2.4 Onlayn bankçılıq	5
2.5 Kriptovalyutalar	5
2.6 WiFi şəbəkələri	5
3 Təhlükəsizlik xidmətləri	6
3.1 Konfidensiallıq (Confidentiality)	6
3.2 Bütövlük (Integrity)	6
3.3 Autentikasiya (Authentication)	7
3.4 İnkərar edilməzlik (Non-repudiation)	7
3.5 Dörd xidmətin müqayisəsi	8
4 Kriptografiya ancaq şifrələmə deyil	8
4.1 Kriptografiyanın əhatə etdiyi sahələr	8
4.2 Niyə bu geniş anlayış vacibdir?	9
5 Kerckhoffs prinsipi	10
5.1 Tarixi fon	10
5.2 Prinsipin izahı	10
5.3 Müasir kriptografiyada tətbiqi	11
6 Simmetrik vs Asimmetrik kriptografiya	11
6.1 Simmetrik kriptografiya	12
6.1.1 Simmetrik kriptografiyanın üstünlükləri	12
6.1.2 Simmetrik kriptografiyanın çatışmazlıqları	12
6.1.3 Simmetrik alqoritmlərə nümunələr	13
6.2 Asimmetrik kriptografiya (Açıq açarlı kriptografiya)	13
6.2.1 Asimmetrik kriptografiyanın üstünlükləri	13
6.2.2 Asimmetrik kriptografiyanın çatışmazlıqları	14
6.2.3 Asimmetrik alqoritmlərə nümunələr	14
6.3 Simmetrik və asimmetrik kriptografiyanın müqayisəsi	14
6.4 Real dünyada istifadə: Hibrid yanaşma	14
7 Təhdid modeli (Threat Model)	15
7.1 Hücümçü modelləri	15
7.2 Passiv və aktiv hücümçü	16
7.3 Real dünya hücümçuları	16
8 Nəticə	16

9	Məşğələ Tapşırıqları	18
9.1	Tapşırıq 1: Terminologiya	18
9.2	Tapşırıq 2: Gündəlik həyatda kriptografiya	18
9.3	Tapşırıq 3: Kerckhoffs prinsipi üzərində analiz	18
9.4	Tapşırıq 4: Təhdid modelinin qurulması	18
9.5	Tapşırıq 5: Simmetrik və Asimmetrik sistemlərin müqayisəsi	19
9.6	Tapşırıq 6: Hibrid şifrələmə (Digital Envelope)	19
10	Məşğələ Tapşırıqlarının Ətraflı və Tam Cavabları	20
10.1	Tapşırıq 1: Terminologiya	20
10.2	Tapşırıq 2: Gündəlik həyatda kriptografiya	21
10.3	Tapşırıq 3: Kerckhoffs prinsipi üzərində analiz	21
10.4	Tapşırıq 4: Təhdid modelinin qurulması (Ev Wi-Fi şəbəkəsi)	22
10.5	Tapşırıq 5: Simmetrik və Asimmetrik sistemlərin müqayisəsi	23
10.6	Tapşırıq 6: Hibrid şifrələmə (Digital Envelope) addımları	23

1 Giriş

Kriptoqrafiya — qədim yunan sözlərindən yaranan bir termindir: *kryptós* (gizli) və *gráphein* (yazmaq). Bu gün kriptoqrafiya dedikdə, informasiyanın qorunması üçün istifadə olunan riyazi üsullar və protokollar toplusu başa düşülür (Stinson and Paterson, 2018; Katz and Lindell, 2020).

Tərif 1.1 (Kriptologiya). Kriptologiya — konfidensiallığın, bütövlüyün və həqiqiliyin təmin edilməsi məqsədilə məlumatların şifrələnməsi və deşifrələnməsi üsullarını öyrənən elmdir. Bu termin yunan mənşəli iki sözün birləşməsindən yaranıb: *kryptos* (gizli) və *logos* (elm).

Kriptologiya adətən iki əsas qola bölünür: **kriptoqrafiya** və **kriptoanaliz**. Əslində, bu iki sahə bir-biri ilə sıx əlaqədardır və birinin inkişafı digərinin təkmilləşməsinə birbaşa təsir göstərir.

Tərif 1.2 (Kriptoqrafiya). Kriptoqrafiya — məlumatın konfidensiallığın, bütövlüyünü, autentikliyi və inkarolunmazlığını təmin etmək üçün istifadə olunan riyazi üsullar və protokollar toplusudur (Menezes et al., 1996).

Tərif 1.3 (Kriptoanaliz). Kriptoanaliz — şifrələnmiş sistemləri analiz edən, onların zəif tərəflərini tapan və məxfi açarı bilmədən məlumatı əldə etməyə çalışan sahədir. Sadə dildə desək, kriptoqrafiya "qıfıl hazırlamaqdır", kriptoanaliz "qıfılı açmağa çalışmaqdır".

Bu mühazirələr silsiləsi əsasən kriptoqrafiyanı əhatə edəcək, lakin kriptoanalizin də bir sıra mühüm məqamlarına toxunulacaqdır. İlk mühazirədə kriptoqrafiyanın əsas anlayışları, gündəlik həyatdakı tətbiqləri, təhlükəsizlik xidmətləri, Kerckhoffs prinsipi, təhdid modelləri və iki əsas kriptoqrafiya növü (simmetrik və asimmetrik) haqqında danışacağıq.

Mühazirənin məqsədi

Bu mühazirəni bitirdikdən sonra siz:

- Kriptoqrafiyanın nə olduğunu və gündəlik həyatda harada istifadə olunduğunu izah edə biləcəksiniz;
- Dörd əsas təhlükəsizlik xidmətini (**konfidensiallıq, bütövlük, autentikasiya, inkarolunmazlıq**) izah edə biləcəksiniz (Stallings, 2017);
- Kerckhoffs prinsipini başa düşəcək və mahiyyətini izah edə biləcəksiniz (Kerckhoffs, 1883);
- Təhdid modeli anlayışını və müxtəlif hücumçu modellərini xarakterizə edə biləcəksiniz;
- Simmetrik və asimmetrik kriptoqrafiya arasındakı fundamental fərqləri sadalaya biləcəksiniz (Diffie and Hellman, 1976).

2 Kriptoqrafiyanın Gündəlik Tətbiqləri

Gündəlik həyatda fərqi nə varmadan kriptoqrafiyadan daim istifadə edirik. Aşağıdakı nümunələr kriptoqrafiyanın müasir dünyada nə dərəcədə həlledici rol oynadığını göstərir (Ferguson et al., 2010).

2.1 E-poçt Təhlükəsizliyi

Elektron poçt vasitəsilə göndərilən məlumatların qorunması üçün müxtəlif kriptografik protokollardan istifadə olunur (Callas et al., 2007):

- **PGP (Kifayət qədər yaxşı məxfilik - Pretty Good Privacy)** və **S/MIME** protokolları e-poçtların şifrələnməsini və rəqəmsal imzalanmasını təmin edir (Garfinkel, 1995).
- **Şifrələmə:** E-poçtun məzmununun yalnız göndərən və alan tərəfindən oxuna bilməsini təmin edir.
- **Rəqəmsal imza:** Məktubu alan şəxs onun həqiqətən iddia olunan göndərəndən gəldiyini və yol boyu manipulyasiya edilmədiyini (bütövlüyünü) yoxlaya bilir.

Nümunə 2.1. Tutaq ki, mühasibinizə konfidensial maliyyə hesabatı göndərirsiniz. Əgər e-poçt şifrələnməyibsə, bu məlumat İnternet provayderiniz və ya şəbəkə trafikini izləyən hər hansı kənar şəxs tərəfindən oxuna bilər. PGP ilə şifrələnmiş mesaj isə yalnız mühasibinizin gizli açarı ilə deşifrə oluna bilən "anlaşılmaz simvollar yığınınna" çevrilir.

2.2 Mesajlaşma Tətbiqləri (WhatsApp, Signal)

WhatsApp, Signal və Telegram (Secret Chat rejimində) kimi tətbiqlər **uçdan-uca şifrələmə** (end-to-end encryption) texnologiyasından istifadə edir (Marlinspike and Perrin, 2013):

- Mesajlar göndərən cihazda şifrələnir və yalnız qəbul edən cihazda açılır.
- İnternet üzərindən ötürülən müddətdə mesajlar şifrələnmiş vəziyyətdə olur.
- Hətta xidməti təmin edən şirkət (məsələn, Meta) belə serverlərindən keçən mesajların məzmununu oxuya bilməz.
- Bu sistem adətən mürəkkəb *Signal Protocol* əsasında işləyir (Perrin and Marlinspike, 2016).

Uçdan-uca (End-to-end) şifrələmə

Uçdan-uca şifrələmə — məlumatın yalnız iki son nöqtədə (göndərən və alan cihazda) açıq mətnə olması deməkdir. Aradakı heç bir vasitəçi (server, provayder və ya hücumçu) məlumatı deşifrə edə bilmir.

2.3 Bank Kartları və EMV Texnologiyası

Bank kartlarındakı çiplər EMV (Europay, MasterCard, Visa) standartı çərçivəsində kriptografik əməliyyatlar həyata keçirir (EMVCo, 2008):

- **Dinamik kriptogram:** Hər əməliyyat üçün unikal bir kod yaradılır. Bu, kartın klonlaşdırılmasının qarşısını alır — hücumçu köhnə əməliyyat məlumatını ələ keçirsə belə, onu təkrar istifadə edə bilməz.
- **PIN-in təsdiqi:** PIN (Personal Identification Number - Şəxsi identifikasiya nömrəsi) kodunuz terminala daxil edildikdə, o, açıq şəkildə deyil, kart çipi daxilində kriptografik olaraq yoxlanılır.

Nümunə 2.2. Ödəniş zamanı POS (Point of Sale - Satış nöqtəsi) terminalı kart çipinə təsadüfi bir sorğu (challenge) göndərir. Kart bu sorğunu öz daxilindəki gizli açarlarla imzalayır. Bu proses "şifrəli sübut" rolunu oynayır və kartın saxta olmadığını təsdiqləyir.

2.4 Onlayn bankçılıq

İnternet üzərindən bank əməliyyatları apararkən bir neçə kriptografik mexanizm işləyir (Rescorla, 2018):

- **HTTPS** (Hypertext Transfer Protocol Secure — veb brauzer ilə sayt arasında məlumatın şifrələnmiş şəkildə ötürülməsi) protokolu (TLS/SSL əsasında) veb sahifə ilə brauzer arasındakı trafikə şifrələyir.
- Bu, onlayn bankçılıq məlumatlarınızın kənar şəxslər tərəfindən oxunmasının qarşısını alır.
- Banklar əməliyyatları təsdiqləmək üçün SMS (Short Message Service - Qısa mesaj xidməti) vasitəsilə göndərilən bir dəfəlik kodlardan (OTP - One Time Password - birdəfəlik parol) istifadə edir.

2.5 Kriptovalyutalar

Bitcoin, Ethereum və digər kriptovalyutalar tamamilə kriptografiya üzərində qurulub (Nakamoto, 2008):

- **Rəqəmsal imzalar** — sikkələrin yalnız sahibi tərəfindən xərclənə bilməsini təmin edir.
- **Heş funksiyaları** — blokların bir-birinə bağlanmasını və məlumatların dəyişdirilməzliyini təmin edir.
- **Proof of Work** (İş Sübutu) — yeni blokların yaradılması üçün mürəkkəb riyazi məsələlərin həllini tələb edir (Back, 2002).

2.6 WiFi şəbəkələri

Simsiz şəbəkələr də kriptografiyadan istifadə edir (IEEE, 2004):

- **WPA2 (Wi-Fi Protected Access 2)** və **WPA3** standartları simsiz trafikə şifrələyir.
- Bu, qonşularınızın və ya kafenizdəki digər müştərilərin İnternet trafikinizi dinləməsinin qarşısını alır.
- WiFi şəbəkəsinə qoşularkən daxil etdiyiniz şifrə, əslində, şifrələmə açarını törətmək üçün istifadə olunur.

Ev şəbəkəniz üçün mütləq WPA2 və ya WPA3 təhlükəsizlik protokolunu aktivləşdirin. Köhnə WEP protokolu asanlıqla sındırıla bilər və təhlükəsiz deyil (Beck and Tews, 2009).

3 Təhlükəsizlik xidmətləri

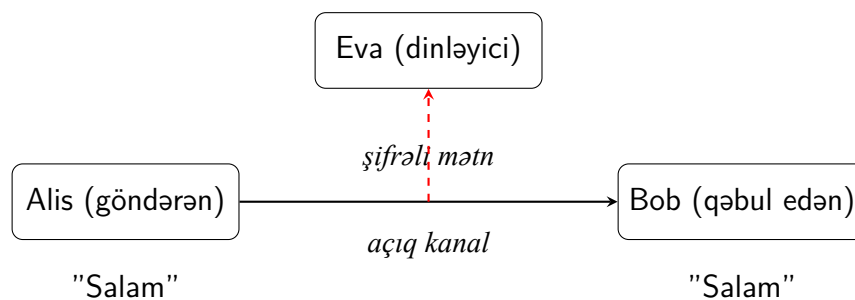
Kriptografiyanın dörd əsas təhlükəsizlik xidməti var. Bunlar İnformasiya Təhlükəsizliyinin təməl daşlarıdır (Stallings, 2017).

3.1 Konfidensiallıq (Confidentiality)

Tərif 3.1 (Konfidensiallıq). Konfidensiallıq — məlumatın icazəsiz şəxslər tərəfindən oxunmasının qarşısını alan xüsusiyyətdir. Başqa sözlə, məlumat yalnız icazəsi olanlar üçün əlçatan olmalıdır.

Konfidensiallıq əsasən **şifrələmə** (encryption) ilə təmin edilir. Şifrələmə prosesində oxuna bilən məlumat (açıq mətn) oxunmayan formata (şifrəli mətn) çevrilir. Yalnız düzgün açara sahib olanlar şifrəli mətni deşifrəleyib orijinal məlumatı əldə edə bilər.

Nümunə 3.1. Alis Boba "Salam" mesajı göndərir. Əgər bu mesaj şifrələnməyibsə, şəbəkəni dinləyən Eva bu mesajı asanlıqla oxuya bilər. Lakin mesaj şifrələnibsə, Eva ancaq mənasız simvollar görəəcək.



Şəkil 1: Konfidensiallıq nümunəsi

Konfidensiallıq təmin etmək üçün istifadə olunan üsullar (Paar and Pelzl, 2010):

- **Simmetrik şifrələmə:** (məs. AES, ChaCha20) — Eyni açar həm şifrələmə, həm də deşifrələmə üçün istifadə olunur.
- **Asimmetrik şifrələmə:** (məs. RSA, ECC) — İctimai və gizli açar cütlərindən istifadə olunur.
- **Giriş nəzarət mexanizmləri:** — Məlumata daxil olmaq səlahiyyətlərinin idarə edilməsi.

3.2 Bütövlük (Integrity)

Tərif 3.2 (Bütövlük). Bütövlük — məlumatın icazəsiz dəyişdirilməsinin qarşısını alan və ya hər hansı dəyişikliyi aşkar edən xüsusiyyətdir. Məlumat ötürülmə zamanı dəyişdirilməməlidir.

Bütövlük adətən **heş funksiyaları** (hash functions) və **Mesaj Autentikasiya Kodu** (MAC) ilə təmin edilir (Bellare et al., 1996). Heş funksiyaları məlumatın "barmaq izi"ni çıxarır — məlumatda hər hansı dəyişiklik heş dəyərinə tamamilə fərqli nəticə verir.

Nümunə 3.2. Alis Boba "100 AZN ödə" mesajı göndərir. Əgər bütövlük qorunmursa, aktiv hücumçu, Mallory, mesajı ələ keçirib "1000 AZN ödə" olaraq dəyişdirə bilər. Bütövlük mexanizmi olduqda, Bob mesajın dəyişdirildiyini aşkar edə bilər.

Tamlığı təmin edən mexanizmlər:

- Heş funksiyaları (SHA-256, SHA-3) (NIST, 2015)
- MAC (HMAC, CMAC) (Krawczyk et al., 1997)
- Rəqəmsal imzalar (Rivest et al., 1978)

3.3 Autentikasiya (Authentication)

Tərif 3.3 (Autentikasiya). Autentikasiya — tərəfin həqiqətən iddia etdiyi şəxs olduğunu təsdiqləmə prosesidir. Mesaj kontekstində isə, mesajın həqiqətən müəyyən göndərəndən gəldiyinə əminlikdir.

Autentikasiya iki formada ola bilər:

- **Mənbə autentikasiyası** — mesajın doğru göndərəndən gəldiyini təsdiqləyir
- **İstifadəçi autentikasiyası** — istifadəçinin həqiqətən kim olduğunu təsdiqləyir (şifrə, barmaq izi və s.)

Nümunə 3.3. Alis Boba mesaj göndərir. Bob əmin olmalıdır ki, bu mesaj doğrudan Alisdən gəlib, Ceyrandan yox. Autentikasiya mexanizmi olmadan, Ceyran Alis kimi görünüb saxta mesaj göndərə bilər.

Qeyd 3.1 (Vacib Qeyd). Kriptoqrafik heş funksiyası təkbaşına autentikasiya təmin etmir. Autentikasiya üçün gizli açar istifadə edən mesaj autentikasiya kodu (MAC) və ya rəqəmsal imza tələb olunur.

Autentikasiya üsulları:

- MAC (simmetrik açarla) (Bellare et al., 1996)
- Rəqəmsal imzalar (asimetrik açarla) (Rivest et al., 1978)
- Şifrələr, biometrik məlumatlar

3.4 İnkə edilməzlik (Non-repudiation)

Tərif 3.4 (İnkə edilməzlik). İnkə edilməzlik — göndərənə sonradan mesajı göndərdiyini inkə edə bilməməsi xüsusiyyətidir. Bu, xüsusilə hüquqi əhəmiyyətli əməliyyatlarda vacibdir (Stinson and Paterson, 2018).

İnkə edilməzlik adətən **rəqəmsal imzalar** ilə təmin edilir. Rəqəmsal imza, göndərənə gizli açarı ilə yaradılır və hər kəs onun açıq açarı ilə imzanı yoxlaya bilər (Rivest et al., 1978).

Nümunə 3.4. Alis Boba "1000 AZN borc ver" mesajı göndərir. Sonra deyir: "Mən belə bir mesaj göndərməmişəm!" Rəqəmsal imza varsa, Bob imzanı göstərərək Alisin yalan danışdığını sübut edə bilər.

Qeyd 3.2. Simmetrik kriptoqrafiya (eyni açarla şifrələmə) inkə edilməzlik təmin etmir. Çünki açar həm göndərəndə, həm də alıcıda olduğu üçün, alıcı da həmin imzanı özü yarada bilər. İnkə edilməzlik üçün mütləq asimetrik kriptoqrafiya (açıq açar - gizli açar) lazımdır (Diffie and Hellman, 1976).

3.5 Dörd xidmətin müqayisəsi

Aşağıdakı cədvəl dörd təhlükəsizlik xidmətini ümumiləşdirir:

Xidmət	Məqsəd	Əsas texnika
Konfidensiallıq	Gizlilik	Şifrələmə
Bütövlük	Dəyişdirilməzlik	Heş, MAC, imza
Autentikasiya	Mənbə təsdiqi	MAC, imza
İnkə edilməzlik	İnkərin qarşısı	Rəqəmsal imza

Bu xidmətləri yadda saxlamaq üçün İngilis dilində "CIAAN" abbreviaturasından istifadə edə bilərsiniz:

- Confidentiality (Konfidensiallıq)
- Integrity (Bütövlük)
- Availability (Əlçətanlıq) - Bu kursda bu məqama biz toxunmuruq
- Authentication (Autentikasiya)
- Non-repudiation (İnkə edilməzlik)

4 Kriptoqrafiya ancaq şifrələmə deyil

Çox vaxt kriptoqrafiya deyildikdə insanların ağına ilk olaraq şifrələmə gəlir. Lakin kriptoqrafiya daha geniş bir sahədir və şifrələmə onun yalnız bir hissəsidir (Menezes et al., 1996).

Kriptoqrafiya təkcə şifrələmə deyil

Kriptoqrafiya məlumatın gizlədilməsi (şifrələmə) ilə yanaşı, onun tamlığının qorunması, mənbəyinin təsdiqlənməsi, müəllifliyinin inkə edilməməsi və tərəflər arasında təhlükəsiz əlaqənin qurulması kimi geniş spektrli məsələləri əhatə edir.

4.1 Kriptoqrafiyanın əhatə etdiyi sahələr

- **Şifrələmə (Encryption):** Məlumatın gizliliyini təmin edir. Konfidensiallıq xidmətinin əsas alətidir.
- **Heş funksiyaları (Hash functions):** İxtiyari ölçülü məlumatdan sabit ölçülü "barmaq izi" çıxarır. Məlumatın tamlığını yoxlamaq, parolların saxlanması, rəqəmsal imzaların sürətləndirilməsi kimi sahələrdə istifadə olunur (NIST, 2015).
- **Məsaj Autentikasiya Kodları (MAC):** Simmetrik açarlarla məlumatın həm tamlığını, həm də mənbə autentikasiyasını təmin edir (Bellare et al., 1996).
- **Rəqəmsal imzalar (Digital signatures):** Asimmetrik kriptoqrafiya əsasında işləyərək məlumatın mənbəyini təsdiqləyir və inkə edilməzlik təmin edir (Rivest et al., 1978).

- **Açar mübadiləsi protokolları (Key exchange):** İki tərəfin təhlükəsiz olmayan kanal üzərindən ortaq gizli açar razılaşdırmasını təmin edir. Diffi-Hellman protokolu buna ən məşhur nümunədir (Diffie and Hellman, 1976).
- **Kriptografik protokollar:** TLS/SSL (təhlükəsiz veb əlaqə), SSH (təhlükəsiz uzaq bağlantı), Signal protokolu (təhlükəsiz mesajlaşma) kimi mürəkkəb sistemlər (Rescorla, 2018; Perrin and Marlinspike, 2016).
- **Sıfır bilik sübutları (Zero-knowledge proofs):** Bir tərəfin digər tərəfə bir məlumatı bildiyini, lakin bu məlumatın özünü açıqlamadan sübut etməsinə imkan verir.
- **Homomorf şifrələmə (Homomorphic encryption):** Şifrələnmiş məlumat üzərində onu deşifrələmədən riyazi əməliyyatlar aparmağa imkan verir.

Nümunə 4.1 (Şifrələmədən başqa kriptografik alətlərin istifadəsi).

- Veb səhifələrdə şifrənizi daxil edərkən, server bu şifrənin heş dəyərini saxlayır. Siz daxil etdikdə, daxil etdiyiniz şifrənin heşi ilə serverdəki heş müqayisə edilir. Burada şifrələmə yox, heş funksiyası istifadə olunur.
- Bitcoin və digər kriptovalyutalarda sikkələrin sahibliyini sübut etmək üçün rəqəmsal imzalar istifadə olunur, şifrələmə deyil (Nakamoto, 2008).
- WhatsApp mesajlarınız end-to-end şifrələnir, lakin bunun üçün ilk növbədə tərəflər arasında açarların razılaşdırılması lazımdır. Bu mərhələdə açar mübadiləsi protokolları işləyir (Marlinspike and Perrin, 2013).

4.2 Niyə bu geniş anlayış vacibdir?

Kriptografiyanı ancaq şifrələmə kimi başa düşmək bir neçə səbəbdən yanlışdır:

Kriptografiyanı ancaq şifrələmə kimi başa düşməyin riskləri

1. **Təhlükəsizlik zəiflikləri:** Şifrələmə məlumatı gizlədir, lakin onun dəyişdirilmədiyini təmin etmir. Məsələn, şifrələnmiş bank əməliyyatı ələ keçirilib təkrar göndərilə bilər (replay attack). Bunun qarşısını almaq üçün bütövlük mexanizmləri (MAC, rəqəmsal imza) lazımdır.
2. **Hüquqi nəticələr:** Şifrələnmiş bir müqavilə göndərdinizsə, amma rəqəmsal imza yoxdursa, qarşı tərəf sonradan "bu müqaviləni mən göndərməmişəm" deyə bilər. İnkər edilməzlik olmadan hüquqi mübahisələrdə çətinlik yaranar.
3. **Praktiki məhdudiyyətlər:** Şifrələmə tək başına təhlükəsiz əlaqə qurmaq üçün kifayət deyil. Tərəflər əvvəlcə ortaq açar razılaşdırmalı, bir-birlərini tanımalı (autentikasiya), mesajların dəyişdirilmədiyinə əmin olmalı (bütövlük) və s.

Qeyd 4.1 (Düzgün baxış). Kriptografiya — məlumat təhlükəsizliyinin riyazi əsaslarını öyrənən elmdir. Şifrələmə bu elmin yalnız bir alətidir. Təhlükəsiz sistem qurmaq üçün bütün bu alətləri birgə və düzgün istifadə etmək lazımdır (Ferguson et al., 2010).

Yadda saxla

Təhlükəsiz bir sistem qurarkən özünüzlə sual verin:

- Məlumat gizli qalmalıdır? → Şifrələmə lazımdır
- Məlumat dəyişdirilə bilərmi? → Bütövlük mexanizmi (MAC/heş) lazımdır
- Məlumatın kimdən gəldiyi vacibdir? → Autentikasiya lazımdır
- Göndərən sonradan inkar edə bilərmi? → Rəqəmsal imza lazımdır

Çox vaxt bu sualların hamısına "bəli" cavabı verilir və buna görə də müasir təhlükəsiz sistemlər birdən çox kriptografik aləti bir yerdə istifadə edir.

5 Kerckhoffs prinsipi

5.1 Tarixi fon

1883-cü ildə holland əsilli dilçi və kriptograf **Ağust Kerckhoffs** (1835-1903) hərbi kriptografiya haqqında yazdığı məqalədə altı prinsip irəli sürdü. Bunlardan ən məşhuru ikinci prinsipdir və bu gün "Kerckhoffs prinsipi" kimi tanınır (Kerckhoffs, 1883).

Kerckhoffs prinsipi

"Kriptosistem, sistem haqqında hər şey (alqoritm, protokol, şifrə və s.) ictimai olsa belə, yalnız açarın gizli qalması şərti ilə təhlükəsiz olmalıdır."

Başqa sözlə, sistemin təhlükəsizliyi gizli saxlanılan alqoritmlərdən asılı olmamalıdır. Yeganə gizli kəmiyyət açar olmalıdır (Shannon, 1949).

5.2 Prinsipin izahı

Kerckhoffs prinsipini bir nümunə ilə izah edək:

Tutaq ki, iki fərqli şifrələmə sistemi var:

1. **Gizli alqoritm:** Alqoritmin özü gizli saxlanılır. Şirkət daxilində işlənilir və heç yerdə dərc olunmayıb.
2. **Açıq alqoritm:** Alqoritm tamamilə açıqdır, istənilən kriptograf onu təhlil edə bilər. Yalnız açar gizlidir.

Hansı daha təhlükəsizdir? Kerckhoffs prinsipinə görə, ikincisi daha təhlükəsizdir. Çünki:

- Gizli alqoritmin zəiflikləri aşkar edilməyə bilər (çünki heç kim onu analiz etmir).
- Alqoritm uzun müddət ərzində gizli qalmaz — əks mühəndislik (reverse engineering) həmişə mümkündür (Anderson, 2008).
- Gizlilik pozulanda bütün sistem çökür, açarları dəyişmək kifayət etmir.

- Açıq alqoritmlər minlərlə mütəxəssis tərəfindən analiz edilir, zəifliklər aşkarlanır və aradan qaldırılır.

Nümunə 5.1 (Tarixi uğursuzluq: CSS sistemi). DVD-ləri qeyri-qanuni kopyalanmaqdan qorumaq üçün hazırlanmış **CSS (Content Scrambling System - Məzmunun Qarışdırılması Sistemi)** alqoritm uzun müddət gizli saxlanılırdı. Lakin 1999-cu ildə 15 yaşlı bir proqramçı tərəfindən bu gizli alqoritm əks-mühəndislik (reverse engineering) vasitəsilə sındırıldı və bütün sistem iflic oldu (Schneier, 2000).

Əgər CSS sistemi Kerckhoff prinsipinə uyğun hazırlansaydı:

- Alqoritm ictimaiyyətə açıq olardı və kriptograflar tərəfindən sınaqdan keçirilərək zəif tərəfləri əvvəlcədən müəyyən edilərdi;
- Sistem sındırıldıqda bütün arxitekturanı dəyişməyə ehtiyac qalmazdı, sadəcə açarları yeniləmək kifayət edərdi.

5.3 Müasir kriptografiyada tətbiqi

Kerckhoffs prinsipi müasir kriptografiyanın təməl daşdır. Bütün standartlaşdırılmış alqoritmlər (AES, SHA-256, RSA, ECC) tamamilə açıqdır. İstənilən şəxs onların spesifikasiyasını oxuya, təhlil edə, hətta öz implementasiyasını yazı bilər (Ferguson et al., 2010).

Qeyd 5.1. Açıq alqoritmlərin üstünlükləri:

- **Kollektiv analiz:** Minlərlə kriptograf alimləri açıq alqoritmləri analiz edir, zəifliklər aşkar olunan kimi düzəldilir.
- **Standartlaşma:** Açıq alqoritmlər beynəlxalq standartlara çevrilir, müxtəlif sistemlər bir-biri ilə uyğun işləyə bilər.
- **Etibar:** Açıq alqoritmlərə etibar daha yüksəkdir, çünki heç bir gizli arxa qapı (backdoor) olmadığından əmin olmaq olar (Schneier, 2015).

Kriptografin qızıl qaydası

Əgər kimsə sizə "tamamilə gizli, heç kimin bilmədiyi və sındırılması qeyri-mümkün olan xüsusi alqoritm" təklif edərsə, bu ciddi şübhə doğurmalıdır. Həqiqi təhlükəsizlik — gizlilikdə deyil, ictimaiyyətə açıq olan, dünya kriptografları tərəfindən illərlə analiz edilmiş və zamanın sınağından keçmiş alqoritmlərdədir.

Heç vaxt öz fərdi şifrələmə alqoritmınızı yaratmağa və tətbiq etməyə çalışmayın — ən təcrübəli mütəxəssislər belə bu yolda kritik səhvlər edirlər (Schneier, 1996). Əgər yeni bir alqoritm hazırlamısınızsa, onun təhlükəsizliyinə əmin olmağın yeganə yolu onu elmi ictimaiyyətə təqdim (nəşr) etmək və analiz olunmasına icazə verməkdir.

6 Simmetrik vs Asimmetrik kriptografiya

Kriptografiya iki əsas növə bölünür: simmetrik və asimmetrik (açıq açarlı) kriptografiya (Stinson and Paterson, 2018).

6.1 Simmetrik kriptografiya

Tərif 6.1 (Simmetrik kriptografiya). Simmetrik kriptografiyada şifrələmə və deşifrələmə üçün **eyni açar** istifadə olunur (Paar and Pelzl, 2010).

Simmetrik kriptografiyanın iş prinsipi sadədir: Alis gizli bir açar seçir, bu açarla mesajı şifrələyir və Boba göndərir. Bob da eyni açarla mesajı deşifrələyir.

Formal olaraq, simmetrik şifrələmə sistemi üçlükdən ibarətdir:

$$\Pi = (\text{Gen}, \text{Enc}, \text{Dec})$$

burada:

- **Gen** — təhlükəsizlik parametrindən açar k yaradan alqoritm
- $\text{Enc}_k(m) = c$ — k açarı ilə m mesajını şifrələyib c şifrəli mətnini yaradan alqoritm
- $\text{Dec}_k(c) = m$ — k açarı ilə c şifrəli mətnini deşifrələyib m mesajını bərpa edən alqoritm

və $\text{Dec}_k(\text{Enc}_k(m)) = m$ tələbi ödənməlidir. Yəni ki, Dec funksiyası Enc funksiyasının tərsidir.

6.1.1 Simmetrik kriptografiyanın üstünlükləri

- **Sürət:** Simmetrik alqoritmlər asimmetrik alqoritmlərdən 100-1000 dəfə sürətlidir (Paar and Pelzl, 2010). Bu, onları böyük həcmli məlumatların şifrələnməsi üçün ideal edir.
- **Təhlükəsizlik:** AES-256 kimi müasir simmetrik alqoritmlər bu günə qədər sındırılmayıb və yaxın gələcəkdə sındırılması gözlənilmir.
- **Sadəlik:** Tək açar idarə etmək kifayətdir.
- **Açar uzunluğu:** 128-256 bit kimi qısa açarlar kifayət edir.

6.1.2 Simmetrik kriptografiyanın çatışmazlıqları

- **Açar paylanması problemi:** Açar təhlükəsiz şəkildə necə ötürülməlidir? (Diffie and Hellman, 1976)
- **Miqyashlıq problemi:** n istifadəçi üçün $\frac{n(n-1)}{2}$ açar lazımdır. 1000 istifadəçi üçün təxminən 500,000 açar!
- **İnkar edilməzlik təmin etmir:** Açar hər iki tərəfdə olduğu üçün, alıcı da eyni imzanı yarada bilər.
- **Rəqəmsal imza mümkün deyil:** Rəqəmsal imza üçün asimmetrik kriptografiya lazımdır (Rivest et al., 1978).

Nümunə 6.1 (Açar paylanması problemi). Alis və Bob təhlükəsiz bir kanal üzərindən danışmaq istəyirlər. Simmetrik şifrələmə üçün ortaq bir açar lazımdır. Bəs bu açar necə ötürülməlidir? Əgər açarı İnternet üzərindən göndərsələr, hücumçu onu ələ keçirə bilər. Əgər açarı əl ilə çatdırsalar, bu praktiki deyil.

6.1.3 Simmetrik alqoritmlərə nümunələr

- **AES (Advanced Encryption Standard)** — müasir simmetrik şifrələmə standartı (NIST, 2001)
- **ChaCha20** — sürətli axın şifrəsi, mobil cihazlarda geniş istifadə olunur (Bernstein, 2008)
- **DES (Data Encryption Standard)** — köhnə standart, indi təhlükəsiz deyil (of Standards, 1977)
- **Blowfish** — dəyişən açar uzunluqlu şifrə (Schneier, 1994)

Qeyd 6.1 (Vacib Qeyd). Müasir simmetrik şifrələmə alqoritmləri (AES, ChaCha20) özlüyündə deterministik olsa da, praktikada müxtəlif iş rejimləri (CBC, CTR, GCM) və təsadüfi başlanğıc vektorları (IV) və ya nonce istifadə etməklə eyni açıq mətn eyni açar altında müxtəlif şifrəli mənlərə çevrilə bilər. Bu xüsusiyyət statistik hücumların qarşısını alır və semantik təhlükəsizliyi təmin edir.

6.2 Asimmetrik kriptografiya (Açıq açarlı kriptografiya)

Tərif 6.2 (Asimmetrik kriptografiya). Asimmetrik kriptografiyada hər istifadəçinin iki açarı var: **açıq açar** (public key) və **gizli açar** (private key). Açıq açar hamı ilə paylaşılır, gizli açar isə yalnız sahibində olur (Diffie and Hellman, 1976).

Asimmetrik kriptografiyada şifrələmə belə işləyir: Alis Boba gizli mesaj göndərmək istəyir. Alis Bobun **açıq açarı** ilə mesajı şifrələyir və göndərir. Bob öz **gizli açarı** ilə mesajı deşifrələyir. Heç kim Bobun gizli açarı olmadan mesajı deşifrələyə bilməz.

Formal olaraq, asimmetrik şifrələmə sistemi üçlükdən ibarətdir:

$$\Pi = (\text{Gen}, \text{Enc}, \text{Dec})$$

burada:

- **Gen** — təhlükəsizlik parametrindən açar cütü (pk, sk) yaradan alqoritm (pk açıq açar, sk gizli açar)
- $\text{Enc}_{pk}(m) = c$ — pk açıq açarı ilə m mesajını şifrələyib c şifrəli mətnini yaradan alqoritm
- $\text{Dec}_{sk}(c) = m$ — sk gizli açarı ilə c şifrəli mətnini deşifrələyib m mesajını bərpa edən alqoritm

və $\text{Dec}_{sk}(\text{Enc}_{pk}(m)) = m$ tələbi ödənməlidir.

6.2.1 Asimmetrik kriptografiyanın üstünlükləri

- **Açar paylanması problemi həll olunur:** Açıq açarlar açıq şəkildə paylaşıla bilər (Diffie and Hellman, 1976).
- **Miqyashlıq problemi yoxdur:** n istifadəçi üçün cəmi $2n$ açar lazımdır (hər kəsə bir cüt). 1000 istifadəçi üçün 2000 açar.
- **İnkar edilməzlik təmin edilir:** Gizli açar yalnız sahibində olduğu üçün, imzanı başqası yarada bilməz (Rivest et al., 1978).

- **Rəqəmsal imza mümkündür:** İmzalama və imza yoxlama üçün idealdır.

Qeyd 6.2. Asimmetrik kriptografiya açar paylanması problemini həll etsə də, açıq açarın həqiqətən iddia edilən şəxsə məxsus olduğunu təsdiqləmək ayrıca problemidir (açıq açarın autentifikasiyası). Bu məqsədlə sertifikat infrastrukturu (PKI) istifadə olunur.

6.2.2 Asimmetrik kriptografiyanın çatışmazlıqları

- **Yavaşlıq:** Simmetrik şifrələmədən 100-1000 dəfə yavaştır (Paar and Pelzl, 2010). Böyük həcmli məlumatları birbaşa asimmetrik şifrələmək praktiki deyil.
- **Böyük açar uzunluğu:** RSA-2048 açarı 256 bayt, AES-256 açarı isə cəmi 32 baytdır.
- **Kvant təhlükəsi:** Şor alqoritmi ilə kvant kompüterlər RSA və ECC kimi asimmetrik sistemləri sındıra bilər (Shor, 1997).

6.2.3 Asimmetrik alqoritmlərə nümunələr

- **RSA** — Rivest-Shamir-Adleman (1977), faktorizasiya probleminə əsaslanır (Rivest et al., 1978)
- **ECC** — Elliptik əyri kriptografiyası, daha qısa açarlarla eyni təhlükəsizlik (Koblitz, 1987; Miller, 1985)
- **Diffi-Hellman** — açar mübadiləsi protokolu (Diffie and Hellman, 1976)
- **ElGamal** — diskret loqarifm əsaslı şifrələmə (Elgamal, 1985)

6.3 Simmetrik və asimmetrik kriptografiyanın müqayisəsi

Aşağıdakı cədvəl hər iki yanaşmanı müqayisə edir:

Xüsusiyyət	Simmetrik	Asimmetrik
Açar sayı	1	2 (açıq + gizli)
Sürət	Çox sürətli	Yavaş
Açar uzunluğu	128-256 bit	2048-4096 bit (RSA)
Açar paylanması	Böyük problem	Asan
Miqyaslılıq	$O(n^2)$ açar	$O(n)$ açar
İnkər edilməzlik	Yox	Var
Rəqəmsal imza	Mümkün deyil	Mümkündür
İstifadə sahəsi	Məlumat şifrələmə	Açar mübadiləsi, imzalar
Nümunələr	AES, ChaCha20, DES	RSA, ECC, ElGamal

6.4 Real dünyada istifadə: Hibrid yanaşma

Real dünyada həm simmetrik, həm də asimmetrik kriptografiyanın üstünlüklərindən istifadə edən **hibrid yanaşma** tətbiq olunur (Ferguson et al., 2010).

Tərif 6.3 (Hibrid şifrələmə). Hibrid şifrələmə — asimmetrik kriptografiyanın təhlükəsiz açar paylanması üstünlüyü ilə simmetrik kriptografiyanın sürət üstünlüyünü birləşdirən üsuldur.

Hibrid şifrələmə prosesi belə işləyir:

1. **Sessiya açarı yaradılır:** Alis təsadüfi bir simmetrik açar yaradır (sessiya açarı).
2. **Sessiya açarı asimmetrik şifrələnir:** Alis bu sessiya açarını Bobun açıq açarı ilə şifrələyir və Boba göndərir.
3. **Məlumat simmetrik şifrələnir:** Alis əsl mesajı yaratdığı sessiya açarı ilə simmetrik şifrələyir və Boba göndərir.
4. **Bob deşifrəleyir:** Bob əvvəlcə öz gizli açarı ilə sessiya açarını deşifrəleyir, sonra bu açarla mesajı deşifrəleyir.

Bu yanaşma **rəqəmsal zərf** (digital envelope) adlanır (Stallings, 2017).

Nümunə 6.2 (TLS protokolunda hibrid şifrələmə). HTTPS bağlantısı qurarkən (TLS protokolu) məhz bu hibrid yanaşma istifadə olunur (Rescorla, 2018):

1. Müştəri və server əvvəlcə asimmetrik kriptografiya (RSA və ya ECDH) ilə ortaq bir sessiya açarı razılaşdırır.
2. Sonra bütün trafik bu sessiya açarı ilə simmetrik şifrələnir (AES və ya ChaCha20).

Bu yanaşma həm təhlükəsiz, həm də sürətlidir.

Qeyd 6.3 (Praktik qeyd). Asimmetrik alqoritmlər hesablama baxımından simmetrik alqoritmlərdən daha ağırdır. Bu səbəbdən onlar əsasən açar mübadiləsi üçün, simmetrik alqoritmlər isə böyük həcmli məlumatın şifrələnməsi üçün istifadə olunur.

7 Təhdid modeli (Threat Model)

Kriptografik sistem dizayn edərkən ilk sual belədir:

Biz kimdən qorunuruq?

Bu sualın cavabı **təhdid modeli** (threat model) adlanır.

Tərif 7.1 (Təhdid modeli). Təhdid modeli — sistemə qarşı mümkün hücumların və hücumçunun imkanlarının formal təsviridir.

Kriptografiyada təhlükəsizlik mütləq anlayış deyil. Sistem yalnız müəyyən edilmiş hücum modelinə qarşı təhlükəsiz ola bilər.

7.1 Hücumçu modelləri

Kriptografiyada ənənəvi olaraq aşağıdakı obrazlardan istifadə olunur:

- **Alis (Alice)** — göndərən
- **Bob** — qəbul edən
- **Eva (Eavesdropper)** — passiv dinləyici
- **Mallory** — aktiv hücumçu
- **Trent** — etibarlı üçüncü tərəf

7.2 Passiv və aktiv hücumçu

Tərif 7.2 (Passiv hücumçu). Passiv hücumçu yalnız trafiki müşahidə edir, lakin mesajları dəyişdirə bilmir.

Məsələn, Eva şəbəkəni dinləyir, lakin müdaxilə etmir.

Tərif 7.3 (Aktiv hücumçu). Aktiv hücumçu mesajları dəyişdirə, silə, əlavə edə və ya saxta mesaj göndərə bilər.

Mallory mesajı ələ keçirib dəyişdirə bilər.

7.3 Real dünya hücumçuları

Praktikada hücumçu aşağıdakılardan biri ola bilər:

- Şəbəkə administratoru
- WiFi üzərindən dinləyən qonşu
- Daxili işçi
- Dövlət səviyyəli aktor
- Kvant kompüterə malik gələcək hücumçu

Qeyd 7.1 (Konservativ dizayn prinsipi). Kriptosistemlər hər zaman "ən pis ssenari" (worst-case scenario) nəzərə alınaraq dizayn edilir. Bu o deməkdir ki, hücumçunun istifadə olunan alqoritmi, protokolun detallarını və sistemin işləmə mexanizmini tam bildiyi qəbul edilir (Kerckhoffs prinsipi). Sistemin təhlükəsizliyi gizli alqoritmlərə deyil, yalnız gizli saxlanılan açarların möhkəmliyinə əsaslanmalıdır.

Qeyd 7.2 (Təhlükəsizliyin nisbiliyi). Kriptoqrafik təhlükəsizlik mütləq bir anlayış deyil. Bir sistemin "təhlükəsiz" olub-olmaması həmişə konkret müəyyən edilmiş **hücum modelinə** və ya **təhdid modelinə** qarşı təyin edilir. Başqa sözlə, bir sistem müəyyən bir hücumçu tipinə (məsələn, yalnız ötürülən məlumatı dinləyən) qarşı tam təhlükəsiz ola bildiyi halda, daha güclü bir hücumçuya (məsələn, məlumatı dəyişdirə bilən) qarşı zəif ola bilər.

8 Nəticə

Bu ilk mühazirədə kriptoqrafiyanın əsas anlayışlarını öyrəndik:

- Kriptoqrafiya gündəlik həyatımızın hər yerində istifadə olunur — e-poçtdan tutmuş bank kartlarına, WhatsApp-dan tutmuş WiFi-ya qədər (Ferguson et al., 2010).
- Dörd əsas təhlükəsizlik xidməti var: konfidensiallıq, bütövlük, autentikasiya və inkar edilməzlik (Stallings, 2017).
- Kerckhoffs prinsipi deyir: sistem təhlükəsizliyi alqoritmın gizli olmasına deyil, yalnız açarın gizli olmasına əsaslanmalıdır (Kerckhoffs, 1883).
- Təhdid modeli — hücumçunun imkanlarını və sistemə qarşı mümkün hücumları təsvir edən formal anlayışdır.

- Simmetrik kriptografiya sürətlidir, lakin açar paylanması problemi var (Paar and Pelzl, 2010).
- Asimmetrik kriptografiya açar paylanmasını həll edir, lakin yavaşdır (Diffie and Hellman, 1976).
- Real dünyada hibrid yanaşma istifadə olunur: asimmetrik kriptografiya ilə simmetrik açar ötürülür, sonra məlumat simmetrik şifrələnir (Rescorla, 2018).

Növbəti mühazirə

Növbəti həftə klassik şifrələr (Sezar, Affin) və onların kriptanalizi (tezlik analizi) haqqında danışacağıq.

9 Məşğələ Tapşırıqları

9.1 Tapşırıq 1: Terminologiya

Aşağıdakı terminləri öz sözlərinizlə izah edin (hər biri üçün 2-3 cümlə kifayətdir):

1. Kriptoqrafiya
2. Məxfilik (Confidentiality)
3. Bütövlük (Integrity)
4. Autentikasiya (Həqiqiliyin təsdiqi)
5. İnkərolunmazlıq (Non-repudiation)
6. Kerckhoffs prinsipi
7. Təhdid modeli (Threat model)
8. Simmetrik kriptoqrafiya
9. Asimmetrik kriptoqrafiya
10. Hibrid şifrələmə

9.2 Tapşırıq 2: Gündəlik həyatda kriptoqrafiya

Gündəlik həyatda istifadə etdiyiniz 5 texnologiya və ya xidmət seçin (məsələn: WhatsApp, onlayn bankçılıq, ev Wi-Fi şəbəkəsi, e-poçt, biometrik pasport və s.). Hər biri üçün hansı kriptografik xidmətlərin (konfidensiallıq, bütövlük və s.) necə təmin olunduğunu araşdırın.

9.3 Tapşırıq 3: Kerckhoffs prinsipi üzərində analiz

Bir şirkət "yalnız daxili istifadə üçün" nəzərdə tutulan və alqoritmi gizli saxlanılan bir şifrələmə sistemi hazırlayıb. Onlar iddia edirlər ki, alqoritm gizli olduğu üçün onu sındırmaq daha çətindir.

- Bu yanaşmanın (*Security by Obscurity*) 3 potensial zəif tərəfini yazın.
- Kerckhoffs prinsipi bu ssenaridə niyə vacibdir?

9.4 Tapşırıq 4: Təhdid modelinin qurulması

Ev Wi-Fi şəbəkəniz üçün sadə bir təhdid modeli yaradın:

- Kimlərdən və hansı məlumatları qorumaq istəyirsiniz?
- Hücümçuların potensial imkanları nələrdir?
- Passiv (dinləmə) və aktiv (məlumatı dəyişdirmə) hücum ssenarilərini fərqləndirin.

9.5 Tapşırıq 5: Simmetrik və Asimmetrik sistemlərin müqayisəsi

Aşağıdakı cədvəli müvafiq məlumatlarla doldurun:

Xüsusiyyət	Simmetrik	Asimmetrik
Açar sayı		
Hesablama sürəti		
Açar uzunluğu (tipik)		
Açarların paylanması		
İnkarolunmazlıq		
Nümunə alqoritmlər		

9.6 Tapşırıq 6: Hibrid şifrələmə (Digital Envelope)

”Rəqəmsal zərf” (*Digital Envelope*) prosesini addım-addım izah edin. Hər addımda hansı kriptografiya növündən (simmetrik və ya asimmetrik) istifadə olunduğunu və bunun üstünlüyünü qeyd edin.

Tapşırıqların təhvil verilməsi

Tapşırıqları növbəti məşğələ dərsinə qədər hazırlayın. Seminar zamanı tapşırıqlar əsasında diskussiya aparılacaqdır.

10 Məşğələ Tapşırıqlarının Ətraflı və Tam Cavabları

Bu bölmədə mühazirə tapşırıqları üçün genişləndirilmiş, tam akademik və təfərrüatlı cavablar verilmişdir.

10.1 Tapşırıq 1: Terminologiya

Kriptoqrafiya: Məlumatın konfidensiallığını, bütövlüyünü, autentikliyi və inkarolunmazlığını təmin etmək üçün riyazi üsullar və protokollar toplusunu öyrənən elmdir. O, açıq mətni oxunmaz formata salmaq və ya məlumatın mənbəyini sübut etmək üçün mürəkkəb riyazi alqoritmlərdən istifadə edir.

Məxfilik (Confidentiality): Məlumatın yalnız icazəsi və müvafiq deşifrəlmə açarı olan şəxslər tərəfindən oxuna bilməsini təmin edən təhlükəsizlik xidmətidir. Bu xidmət şəbəkəni dinləyən kənar şəxslərin məlumatın məzmununu ələ keçirməsinin qarşısını alır.

Bütövlük (Integrity): Məlumatın ötürülməsi və ya saxlanması zamanı icazəsiz şəxslər tərəfindən dəyişdirilmədiyini, silinmədiyini və ya əlavələr edilmədiyini zəmanət edən xüsusiyyətdir. Adətən kriptoqrafik heş funksiyaları və MAC mexanizmləri ilə yoxlanılır.

Autentikasiya: Göndərilən mesajın mənbəyinin və ya sistemə daxil olmaq istəyən tərəfin həqiqətən iddia etdiyi subyekt olduğunu doğrulama prosesidir. Məlumatın saxta tərəf tərəfindən deyil, dürüst göndərən tərəfindən yaradıldığını təsdiqləyir.

İnkarolunmazlıq (Non-repudiation): Məlumatı göndərən və ya əməliyyatı yerinə yetirən tərəfin sonradan bu əməliyyatı özünün etmədiyini iddia edə bilməməsidir. Əsasən rəqəmsal imzalar vasitəsilə təmin edilir və hüquqi baxımdan böyük əhəmiyyət kəsb edir.

Kerckhoffs prinsipi: Kriptosistemin təhlükəsizliyinin alqoritmin gizli saxlanılmasına deyil, yalnız və yalnız gizli açarın məxfiliyinə əsaslanmalı olduğunu bildirən təməl prinsipdir. Alqoritm hər kəsə bəlli olsa belə, açar bilinmədiyi müddətcə sistem sındırılamaz qalmalıdır.

Təhdid modeli (Threat model): Müəyyən bir sistemə yönəli biləcək potensial hücumçuları, onların malik olduqları resursları, imkanları və sistemin zəif tərəflərini müəyyənləşdirən analiz çərçivəsidir. Təhlükəsizlik sistemlərinin doğru layihələndirilməsi üçün ilkin şərtidir.

Simmetrik kriptoqrafiya: Məlumatın şifrələnməsi və deşifrələnməsi üçün eyni bir gizli açardan istifadə edən kriptoqrafiya sahəsidir. Yüksək hesablama sürətinə malikdir, lakin açarın təhlükəsiz ötürülməsi və idarə edilməsi çətinlik yaradır.

Asimmetrik kriptoqrafiya: şifrələmə və deşifrələmə üçün bir-biri ilə riyazi bağlı olan iki fərqli açıardan (açıq və gizli) istifadə edən sistemdir. Açıq açar hamı ilə paylaşılır, gizli açar isə yalnız sahibində qalır; bu da açar mübadiləsi problemini həll edir.

Hibrid şifrələmə: Simmetrik və asimmetrik kriptoqrafiyanın üstün cəhətlərini birləşdirən metodologiyadır. Məlumatın özü sürətli simmetrik alqoritmlə, simmetrik seans açarı isə təhlükəsiz asimmetrik alqoritmlə şifrələnərək ötürülür.

10.2 Tapşırıq 2: Gündəlik həyatda kriptografiya

Gündəlik istifadə olunan 5 texnologiya və onların təmin etdiyi təhlükəsizlik xidmətləri:

1. WhatsApp (Messenger):

- *Məxfilik*: Signal protokolu əsasında Uçdan-Uca şifrələmə (*End-to-End Encryption*) vasitəsilə təmin edilir. Mesajlar göndərən cihazda simmetrik alqoritmlə şifrələnir və yalnız qəbul edən cihazda deşifrə olunur.
- *Autentikasiya və Bütövlük*: Tərəflərin identifikasiya açarları (Identity Keys) və HMAC/HKDF mexanizmləri ilə mesajların dəyişdirilmədiyi və doğru şəxsdən gəldiyi təsdiqlənir.

2. Onlayn Bankçılıq (HTTPS / TLS):

- *Məxfilik*: TLS protokolu çərçivəsində AES simmetrik şifrələməsi ilə brauzer və bank serveri arasındakı bütün trafik şifrələnir.
- *Autentikasiya*: Bankın serveri X.509 rəqəmsal sertifikatları (RSA/ECC) vasitəsilə autentifikasiya olunur. İstifadəçi isə parol və SMS/App 2FA (OTP) ilə təsdiqlənir.
- *Bütövlük*: TLS Record Protocol daxilində MAC (Message Authentication Code) istifadə edilərək maliyyə sorğularının yolda dəyişdirilməsinin qarşısı alınır.

3. Ev Wi-Fi Şəbəkəsi (WPA2 / WPA3):

- *Məxfilik*: WPA2-də AES-CCMP, WPA3-də isə AES-GCMP simmetrik alqoritmləri vasitəsilə havadan ötürülən bütün Radio Tezlik (RF) paketləri şifrələnir.
- *Autentikasiya*: WPA3-də SAE (*Simultaneous Authentication of Equals*) protokolu ilə router və cihaz arasında parol əsaslı autentikasiya aparılır.

4. E-poçt Təhlükəsizliyi (PGP / S/MIME):

- *Məxfilik*: Məktubun məzmunu təsadüfi seans açarı ilə (simmetrik), seans açarı isə qəbul edən açıq açarı ilə (asimmetrik) şifrələnir.
- *İnkarolunmazlıq və Bütövlük*: Göndərən məktubu öz gizli açarı ilə rəqəmsal imzalayır (RSA/ECDSA). Qəbul edən bu imzanı yoxlayaraq məktubun dəyişdirilmədiyini və göndərən onu inkar edə bilməyəcəyini sübut edir.

5. Biometrik Pasport (e-Passport):

- *Autentikasiya və Bütövlük*: Pasport çipindəki məlumatlar dövlətin rəqəmsal imzası ilə təsdiqlənir (*Passive Authentication*). Sərhəd keçid məntəqəsində çipin həqiqiliyi RSA/ECDSA sorğu-cavab (*Active Authentication*) mexanizmi ilə yoxlanılır.
- *Məxfilik*: BAC/EAC (*Basic/Extended Access Control*) protokolları ilə pasport çipindəki fərdi məlumatların kənardan icazəsiz oxunmasının (skan edilməsinin) qarşısı alınır.

10.3 Tapşırıq 3: Kerckhoffs prinsipi üzərində analiz

”Security by Obscurity” (Gizlilik vasitəsilə təhlükəsizlik) yanaşmasının 3 potensial zəif tərəfi:

1. **Əks-mühəndislik (Reverse Engineering) riski:** Proqram təminatı və ya avadanlıq hücumçunun əlinə keçdikdə, təcrübəli mütəxəssislər dekompiyasiya və disassemblesiya üsulları ilə gizli alqoritmin işləmə prinsipini qısa müddətdə bərpa edə bilirlər.
2. **Kollektiv analizin və ekspertiza yoxlanışının olmaması:** Qapalı alqoritmlər müstəqil akademik icma və kriptanalitiklər tərəfindən sınaqdan keçirilmədiyi üçün, onların tərkibində layihələndirmə səhvləri, riyazi zəifliklər və ya təsadüfi boşluqlar qalır.
3. **Kompromis halında bərpanın son dərəcə baha olması:** Əgər alqoritm sızarsa və ya sındırılsa, bütün sistem müdafiəsiz qalır. Bu halda yalnız açarları dəyişmək kifayət etmir; bütün proqram və ya avadanlıq infrastrukturunu tamamilə yenidən layihələndirmək lazımdır.

Kerckhoffs prinsipinin bu ssenaridə vacibliyi: Kerckhoffs prinsipi bildirir ki, sistemin təhlükəsizliyi sabit və dəyişdirilməsi çətin olan alqoritmin gizliliyinə deyil, asanlıqla dəyişdirilə bilən dinamik kəmiyyətə — gizli açara dayanmalıdır. Bu prinsipi tətbiq etməklə şirkət alqoritmi ictimaiyyətə açır, onun kriptograflar tərəfindən zərbələrə dözümlülüyünü test etdirir və alqoritm bəlli olsa belə, yalnız açarı gizli saxlamaqla uzunmüddətli və etibarlı təhlükəsizlik əldə edir.

10.4 Tapşırıq 4: Təhdid modelinin qurulması (Ev Wi-Fi şəbəkəsi)

• Kimlərdən və hansı məlumatları qorumaq istəyirik?

- *Qorunan subyektlər (Aktivlər):* Şəxsi cihazların IP/MAC ünvanları, şifrələnməmiş veb trafik (HTTP), şəxsi şifrələr, onlayn bankçılıq sessiyaları, evdəki IoT cihazlarına (kamera, smart TV) giriş hüquqları.
- *Potensial hücumçular:* Pulsuz İnternet istifadə etmək istəyən qonşular, küçədən şəbəkəni dinləyən kənar şəxslər (*wardrivers*), şəbəkə trafikini ələ keçirib şəxsi məlumatları oğurlamaq istəyən kiberquldurlar.

• Hücumçuların potensial imkanları:

- Şəbəkə paketlərini dinləmək (*Promiscuous mode* dəstəkləyən Wi-Fi kartları vasitəsilə).
- Deavtentikasiya (*Deauth*) paketləri göndərərək cihazları şəbəkədən üzmək və handshake paketlərini tutmaq.
- Wi-Fi şifrəsini sındırmaq üçün sözlük (*dictionary attack*) və ya kobud güc (*brute-force*) hücumları həyata keçirmək.
- Saxta giriş nöqtəsi (*Rogue AP / Evil Twin*) yaradaraq istifadəçiləri aldatmaq.

• Passiv və Aktiv hücum ssenariləri:

- *Passiv hücum (Dinləmə):* Hücumçu Wi-Fi şəbəkəsinə qoşulmadan, sadəcə havada gəzən paketləri (*monitoring mode* ilə) tutur. O, şəbəkənin trafik həcmi, qoşulan cihazların MAC ünvanlarını və əgər şifrələnməmiş daxil olunubsa, baxılan veb saytların ünvanlarını analiz edir. Şəbəkəyə heç bir müdaxilə etmədiyi üçün onu aşkar etmək demək olar ki, qeyri-mümkündür.
- *Aktiv hücum (Məlumatı dəyişdirmə/Müdaxilə):* Hücumçu şəbəkəyə qoşulur və ya araya girərək (*Man-in-the-Middle - MitM*) trafiki dəyişdirir. Məsələn, ARP Spoofing vasitəsilə router ilə cihaz arasına girir, istifadəçinin daxil olduğu veb səhifələrə saxta kodlar yerləşdirir və ya router-in DNS parametrlərini dəyişərək istifadəçini saxta bank saytına yönləndirir.

10.5 Tapşırıq 5: Simmetrik və Asimmetrik sistemlərin müqayisəsi

Xüsusiyyət	Simmetrik	Asimmetrik
Açar sayı	1 ədəd (həm şifrələmə, həm deşifrələmə üçün ortaq gizli açar)	2 ədəd (bir-biri ilə bağlı Açıq açar və Gizli açar cütü)
Hesablama sürəti	Çox sürətlidir (aparat səviyyəsində dəstəklənir, Gbit/s)	Nisbətən yavaşıdır (mürəkkəb riyazi əməliyyatlar tələb edir)
Açar uzunluğu (tipik)	Qısa: 128 bit, 192 bit, 256 bit	Uzun: RSA üçün 2048–4096 bit, ECC üçün 256–384 bit
Açarların paylanması	Çətindir (açarın təhlükəsiz kanalla əvvəlcədən ötürülməsi lazımdır)	Asandır (açıq açar hər kəsə sərbəst paylana bilər)
İnkaronunmamlıq	Təmin etmir (açar hər iki tərəfdə olduğu üçün qarşı tərəf saxtalaşıra bilər)	Təmin edir (yalnız sahibinə məxsus gizli açarla rəqəmsal imza vasitəsilə)
Nümunə alqoritmlər	AES, ChaCha20, DES, 3DES, Blowfish	RSA, ECC (ECDSA/ECDH), Diffie-Hellman, ElGamal

10.6 Tapşırıq 6: Hibrid şifrələmə (Digital Envelope) addımları

”Rəqəmsal zərf” (*Digital Envelope*) böyük həcmli məlumatları həm sürətli, həm də təhlükəsiz şəkildə ötürmək üçün tətbiq edilir. Prosesin addım-addım izahı:

1. Seans açarının yaradılması və Məlumatın şifrələnməsi (Simmetrik mərhələ):

- *Əməliyyat*: Göndərən (Alis) təsadüfi generator vasitəsilə birdəfəlik simmetrik açar (Seans açarı — *Session Key*) yaradır. Göndəriləcək əsas məlumat bu seans açarı ilə simmetrik alqoritm (məsələn, AES-256) vasitəsilə şifrələnir.
- *Səbəb/Üstünlük*: Simmetrik şifrələmə son dərəcə sürətlidir və böyük faylları anında şifrələyə bilər.

2. Seans açarının ”Zərfə” salınması (Asimmetrik mərhələ):

- *Əməliyyat*: Alis qəbul edən (Bobun) **Açıq açarını** (*Public Key*) götürür və 1-ci addımda istifadə etdiyi *Seans açarını* bu açıq açarla asimmetrik olaraq (məsələn, RSA ilə) şifrələyir. Bu şifrələnmiş seans açarı ”Rəqəmsal Zərf” adlanır.
- *Səbəb/Üstünlük*: Açarın təhlükəsiz kanal olmadan İnternet üzərindən ötürülməsi problemini ortadan qaldırır.

3. Ötürmə (Kanal mərhələsi):

- *Əməliyyat*: Alis şifrələnmiş əsas məlumatı və şifrələnmiş seans açarını (Rəqəmsal zərfi) bir yerdə Boba göndərir.

4. Zərfin açılması və Məlumatın Deşifrələnməsi (Qəbul etmə mərhələsi):

- *Əməliyyat*: Bob mesajı aldıqda, əvvəlcə özünün **Gizli açarı** (*Private Key*) vasitəsilə rəqəmsal zərfin deşifrə edir və orijinal *Seans açarını* əldə edir. Sonra həmin seans açarı ilə simmetrik şifrələnmiş əsas məlumatı deşifrələyib oxuyur.

Hibrid Şifrələmənin Ümumi Üstünlüyü: Bu metod asimmetrik kriptografiyanın yavaşlığını simmetrik kriptografiyanın açar paylanması problemi ilə kompensasiya edir. Nəticədə böyük məlumatlar hesablama resurslarını yükləmədən yüksək sürətlə və tam təhlükəsiz şəkildə ötürülür.

İstinadlar

- R. J. Anderson. *Security Engineering: A Guide to Building Dependable Distributed Systems*. Wiley, Indianapolis, 2nd edition, 2008. ISBN: 978-0470068526.
- A. Back. Hashcash - a denial of service counter-measure. In *USENIX Technical Conference*, 2002.
- M. Beck and E. Tews. Practical attacks against wep and wpa. In *Proceedings of the Second ACM Conference on Wireless Network Security*, pages 79–86. ACM, 2009. doi: 10.1145/1514274.1514286.
- M. Bellare, R. Canetti, and H. Krawczyk. Keying hash functions for message authentication. In *Advances in Cryptology - CRYPTO '96*, volume 1109 of *Lecture Notes in Computer Science*, pages 1–15. Springer, 1996. doi: 10.1007/3-540-68697-5_1.
- D. J. Bernstein. Chacha, a variant of salsa20. Technical report, University of Illinois at Chicago, 2008. <https://cr.y.p.to/chacha/chacha-20080128.pdf>.
- J. Callas, L. Donnerhake, H. Finney, D. Shaw, and R. Thayer. Openpgp message format, November 2007. <https://www.rfc-editor.org/info/rfc4880>.
- W. Diffie and M. E. Hellman. New directions in cryptography. *IEEE Transactions on Information Theory*, 22(6):644–654, November 1976. doi: 10.1109/TIT.1976.1055638.
- T. Elgamal. A public key cryptosystem and a signature scheme based on discrete logarithms. *IEEE Transactions on Information Theory*, 31(4):469–472, 1985. doi: 10.1109/TIT.1985.1057074.
- EMVCo. *EMV Integrated Circuit Card Specifications for Payment Systems*. EMVCo, 4.3 edition, 2008. <https://www.emvco.com/specifications.aspx>.
- N. Ferguson, B. Schneier, and T. Kohno. *Cryptography Engineering: Design Principles and Practical Applications*. Wiley, Indianapolis, 2010. ISBN: 978-0470474242.
- S. Garfinkel. *PGP: Pretty Good Privacy*. O'Reilly Media, Sebastopol, CA, 1995. ISBN: 978-1565920989.
- IEEE. Ieee standard for information technology - telecommunications and information exchange between systems - local and metropolitan area networks - specific requirements - part 11: Wireless lan medium access control (mac) and physical layer (phy) specifications. Technical Report IEEE Std 802.11-2004, Institute of Electrical and Electronics Engineers, 2004. https://standards.ieee.org/standard/802_11-2004.html.
- J. Katz and Y. Lindell. *Introduction to Modern Cryptography*. CRC Press, Boca Raton, 3rd edition, 2020. ISBN: 978-0815354369.

- A. Kerckhoffs. La cryptographie militaire. *Journal des sciences militaires*, 9:5–38, 1883. Kerckhoffs prinsipinin orijinal təqdimatı. "Il faut qu'il n'exige pas le secret, et qu'il puisse sans inconvénient tomber entre les mains de l'ennemi" — Sistem gizlilik tələb etməməli və düşmənin əlinə keçdikdə problem yaratmamalıdır.
- N. Koblitz. Elliptic curve cryptosystems. *Mathematics of Computation*, 48(177):203–209, 1987. doi: 10.1090/S0025-5718-1987-0866109-5.
- H. Krawczyk, M. Bellare, and R. Canetti. Hmac: Keyed-hashing for message authentication, February 1997. <https://www.rfc-editor.org/info/rfc2104>.
- M. Marlinspike and T. Perrin. The signal protocol. Technical report, Open Whisper Systems, 2013. <https://signal.org/docs/>.
- A. J. Menezes, P. C. van Oorschot, and S. A. Vanstone. *Handbook of Applied Cryptography*. CRC Press, 1996.
- V. S. Miller. Use of elliptic curves in cryptography. *Advances in Cryptology - CRYPTO '85*, 218:417–426, 1985. doi: 10.1007/3-540-39799-X_31.
- S. Nakamoto. Bitcoin: A peer-to-peer electronic cash system. 2008. <https://bitcoin.org/bitcoin.pdf>.
- NIST. Advanced encryption standard. Technical Report FIPS PUB 197, U.S. Department of Commerce, 2001.
- NIST. Secure hash standard (shs), 2015. FIPS PUB 180-4. <https://doi.org/10.6028/NIST.FIPS.180-4>.
- N. B. of Standards. Data encryption standard. Technical Report FIPS PUB 46, U.S. Department of Commerce, 1977.
- C. Paar and J. Pelzl. *Understanding Cryptography: A Textbook for Students and Practitioners*. Springer, Berlin, 2010. ISBN: 978-3642041006.
- T. Perrin and M. Marlinspike. The double ratchet algorithm. Technical report, Open Whisper Systems, 2016. <https://signal.org/docs/specifications/doubleratchet/>.
- E. Rescorla. The transport layer security (tls) protocol version 1.3, August 2018. <https://www.rfc-editor.org/info/rfc8446>.
- R. L. Rivest, A. Shamir, and L. M. Adleman. A method for obtaining digital signatures and public-key cryptosystems. *Communications of the ACM*, 21(2):120–126, 1978. doi: 10.1145/359340.359342.
- B. Schneier. Description of a new variable-length key, 64-bit block cipher (blowfish). In *Fast Software Encryption (FSE '93)*, volume 809 of *Lecture Notes in Computer Science*, pages 191–204. Springer, 1994. doi: 10.1007/3-540-58108-1_24.
- B. Schneier. *Applied Cryptography: Protocols, Algorithms, and Source Code in C*. John Wiley & Sons, 2 edition, 1996.
- B. Schneier. *Secrets and Lies: Digital Security in a Networked World*. Wiley, New York, 2000. ISBN: 978-0471253112.

- B. Schneier. *Data and goliath: The hidden battles to collect your data and control your world*. *W.W. Norton & Company*, 2015. ISBN: 978-0393244816.
- C. E. Shannon. Communication theory of secrecy systems. *Bell System Technical Journal*, 28 (4):656–715, 1949.
- P. W. Shor. Polynomial-time algorithms for prime factorization and discrete logarithms on a quantum computer. *SIAM Journal on Computing*, 26(5):1484–1509, 1997. doi: 10.1137/S0097539795293172.
- W. Stallings. *Cryptography and Network Security: Principles and Practice*. Pearson, 7 edition, 2017.
- D. R. Stinson and M. B. Paterson. *Cryptography: Theory and Practice*. CRC Press, Boca Raton, 4th edition, 2018. ISBN: 978-1138197015.